
Web Application Penetration Test Report — v1.0

Target System: OWASP Juice Shop

Performed by the OpenHack Security Agent

Issued by Jane Doe (jane.doe@openhack.sec)

2026-02-26

Contents

1 Document Control	2
2 Executive Summary	3
3 Execution of the Security Penetration Test	4
3.1 Subject Under Test	4
3.2 Scope	4
3.3 In scope	4
3.4 Out of scope	4
3.5 Methodology	4
3.6 Events	5
4 Risk Assessment	6
4.1 CVSS	6
4.2 Risk Categories	7
4.3 Vulnerability States	8
5 Summary of Findings	9
6 Findings and Remediation	10
6.1 Finding	10
6.1.1 Unauthenticated access to Swagger/OpenAPI docs for B2B API	10
6.2 Finding	11
6.2.1 SQL injection in product search parameter (q)	11
6.3 Finding	12
6.3.1 Broken access control: unauthenticated access to /rest/admin application configuration	12
6.4 Finding	13
6.4.1 Verbose error pages on /redirect leak stack traces and internal paths	13
6.5 Finding	14
6.5.1 Unauthenticated directory listing and sensitive file download via /ftp	14
6.6 Finding	15
6.6.1 Information disclosure: unauthenticated access to /api/Hints reveals full hint content	15
7 Appendix A - Lists, Scripts and Raw Data	17

8 Appendix B - List of Abbreviations

18

DRAFT

Scope

OpenHack Security Agent was engaged by Bjoern Kimminich to conduct an external IT security investigation. The subject of the investigation was the “OWASP Juice Shop”.

The test was performed using a local instance of the application at `http://juiceshop:3000` in a dedicated test environment..

Objective

The objective of the IT security investigation was to identify vulnerabilities and security gaps which, in the event of misuse, would have an impact on the availability, integrity and confidentiality of the defined applications and/or systems and the data processed on them. The result of this project is a report that contains a management summary of all relevant findings and a compilation of recommended measures.

The technical IT security audit is not a substantive audit effort to ensure that all vulnerabilities and security gaps existing at the time of the audit are identified. There is a possibility that established safeguards will effectively prevent identification and exploitation of vulnerabilities and security gaps. The client acknowledges that this is not an indicator of deficiencies in engagement performance and that additional unidentified vulnerabilities and security gaps may exist.

Disclaimer

‘OpenHack Security Agent’ conducted the security penetration test on behalf of ‘Bjoern Kimminich’. This report has been prepared exclusively for ‘Bjoern Kimminich’. It is intended exclusively for internal use and is accordingly not designed to serve third parties as a basis for their decisions, unless agreed otherwise in writing. Third parties may not derive any rights or otherwise benefit from this engagement unless agreed otherwise in writing. Affiliated companies of the client are also considered “third parties” within the meaning of this engagement.

‘OpenHack Security Agent’ does not assume any liability or legal claims against third parties unless agreed otherwise in writing or a disclaimer cannot effectively be implemented.

It is the sole responsibility of anyone who becomes aware of the work results summarized in this report to decide to what extent and in what way the information is useful or appropriate and to supplement, check or update it as part of their own review.

No adjustments will be made to the report to reflect events or circumstances that occur after the report is issued, unless required by law.

The recommendations in this report are general and applicable in many different environments but could have unpredictable effects in specific environments. Therefore, any actions derived from the recommendations should be carefully considered and implemented through the regular change process. This should include appropriate testing of the changes on a test environment prior to going live. If the changes are not tested in advance in an identically configured test environment, failures or other damage cannot be ruled out.

Please note: Technical descriptions (or parts thereof) in this report may be taken from the OWASP Testing Guide (www.owasp.org).

1 Document Control

Document Status

Title	Security Assessment Report
Document Owner	OpenHack Security Agent
Classification	Strictly Confidential
Project Timeframe	2026-02-26

Version History

Version	Date	State	Author	Comments
0.1	2026-02-26	Draft	Jane Doe	-
1.0	2026-02-26	Final document	Jane Doe	-

Contact Persons - Assessor

Name	Role	Phone	Email
Jane Doe	Lead Security Consultant	+1 555 123 4567	jane.doe@openhack.sec
John Smith	Security Consultant	+1 555 234 5678	john.smith@openhack.sec

Contact Persons - Client

Name	Role	Phone	Email
Bjoern Kimminich	Project Lead	+1 555 345 6789	bjoern.kimminich@owasp.org

2 Executive Summary

OpenHack Security Agent (hereinafter referred to as “ASSESSOR”) has been commissioned by Bjoern Kimminich (hereinafter referred to as “CLIENT”) to carry out a penetration test.

The penetration test of the OWASP Juice Shop application took place on **2026-02-26**.

For this purpose, the web application, accessible at <http://juiceshop:3000>, was tested from the perspective of an external attacker. User-provided onboarding notes: - Methods/limits/time box: none - Auth: none - Constraints: yes

As part of the test, a total of 6 vulnerabilities were identified: 0 critical, 2 high, 4 medium, 0 low, and 0 informational.

Critical: **0** | High: **2** | Medium: **4** | Low: **0** | Informational: **0** | Total: **6**

Table 2.1: Overview of Findings

Severity Count	
Critical	0
High	2
Medium	4
Low	0
Informational	0
Total	6

A description of the scope and test environment can be found in Chapter 3. Chapter 4 presents the risk assessment methodology. Chapter 5 provides a summary of findings. Chapter 6 contains the detailed technical descriptions of the findings including remediation measures.

It is recommended that the remediation of the critical risk vulnerabilities be treated with the highest priority and countermeasures implemented as soon as possible. The vulnerabilities with high and medium risk should also be remedied in the short term. The low-risk vulnerabilities should be treated with lower priority due to their reduced risk, but should still be addressed.

3 Execution of the Security Penetration Test

3.1 Subject Under Test

3.2 Scope

The scope for the assessment was the following targets:

3.3 In scope

- http://juiceshop:3000

3.4 Out of scope

- (none provided)

3.5 Methodology

The security penetration test of the OWASP Juice Shop took place on 2026-02-26.

Scan mode requested: standard. Methods/rate limits/time box: none provided. Auth context: none provided. Constraints: user answered yes (details not provided).

The web application was tested for security vulnerabilities across the following categories. This can be considered a guideline as penetration tests are a creative process and therefore the tests are not limited to what is given here. The base of these categories is the OWASP Top 10 for Web, which is fully covered by this penetration test approach.

Category	Description
Broken Access Control	Users can act outside their permissions, leading to unauthorized viewing, modification, or deletion of data.

Category	Description
Security Misconfiguration	Systems or cloud services are insecurely configured, e.g., through default passwords or unnecessarily enabled features.
Software Supply Chain Failures	Vulnerabilities arise from compromised third-party code, libraries, or build pipelines.
Cryptographic Failures	Sensitive data is exposed through missing, weak, or incorrectly implemented encryption.
Injection	Attackers inject malicious commands (e.g., SQL or shell code) through input fields that the system erroneously executes.
Insecure Design	Fundamental architectural flaws that exist before implementation make an application inherently insecure.
Authentication Failures	Flaws in identity verification allow attackers to take over sessions or guess passwords (brute force).
Software or Data Integrity Failures	Lack of verification of code or data sources leads to acceptance of untrusted updates or serialization data.
Security Logging & Alerting Failures	Attacks go undetected or responses are delayed due to missing logs or absent alert notifications.
Mishandling of Exceptional Conditions	Programs respond inadequately to unforeseen situations, which can lead to crashes or logic errors.

3.6 Events

During the test, the following restrictions or events occurred that may have affected the scope or depth of the assessment:

4 Risk Assessment

4.1 CVSS

The risk assessment of the vulnerabilities found is performed using the industry standard Common Vulnerability Scoring System v3.1 (hereinafter referred to as “CVSS”). This is a standard that can be used to uniformly assess the vulnerability of computer systems and the severity of security vulnerabilities. This makes it possible to compare vulnerabilities more effectively.

The Common Vulnerability Scoring System has a metric structure and is based on values that are divided into three groups: “Base”, “Temporal”, and “Environmental”. To determine the vulnerability scores, each group has its own rules. The values of the Base group are invariant in time and remain the same in different environments. In the Temporal group, the time dependency of a vulnerability is taken into account. For example, the vulnerability of a system to a particular vulnerability decreases over time as more and more countermeasures such as patches become known and available. The Environmental group incorporates various criteria of the specific IT environments into the vulnerability rating.

The CVSS ratings are numerical values on a scale of 0.0 to 10.0, with the highest vulnerability of a system occurring at a value of 10.0. Our rating is based on the Base Metrics (Base Score) and is composed of:

- Attack Vector (AV)
- Attack Complexity (AC)
- Privileges Required (PR)
- User Interaction (UI)
- Scope (S)
- Confidentiality (C)
- Integrity (I)
- Availability (A)

As penetration testers, we can only assess the general threats posed by a vulnerability through Base Metrics. However, we have no insight into the internal structures of our clients. Therefore, the assessment of the specific risks for the client’s systems and business processes must be done by the client. For this purpose, CVSS offers Environmental Metrics. This makes it possible to subsequently adjust the CVSS score of vulnerabilities after the test result has been

submitted before they are remedied. This changes the assessment of the risk and thus the urgency of remediation of a vulnerability. For more information, see [CVSS v3.1 Specification](#).

4.2 Risk Categories

The risk categories used in this report reflect the recommended priority for addressing the vulnerabilities identified during the penetration test. The categorization is based on the probability of exploitation and the significance of the impact. The risk value is calculated using the CVSS v3.1 standard:

Assessment	Risk Category Description
Critical	Critical vulnerabilities that allow an attacker to gain full access to the object under test and its sensitive information. It is possible to cause enormous damage to the client's reputation. Furthermore, these vulnerabilities may allow attackers to gain wide-ranging privileges, including to other systems or applications of the client that have not been investigated in detail within the scope of this project. Exploitation of the vulnerabilities is not prevented and can be reproduced with medium to low effort.
High	Vulnerabilities that may allow an attacker to manipulate sensitive data, damage the client's reputation, gain unauthorized access to sensitive information, or gain unauthorized access to applications or the client's infrastructure. The vulnerabilities are reproducible with medium to high effort.
Medium	Vulnerabilities that may allow an attacker to harm the client's reputation or gain unauthorized access to client data. The privileges that an attacker can gain by exploiting the vulnerabilities are limited.
Low	Security vulnerabilities that do not pose a threat in themselves, but which, for example, provide attackers with useful information about the network and systems. These vulnerabilities allow an attacker only very limited access.
Informational	Anomalies such as functional limitations or inconsistencies. These do not currently represent a risk and have no negative impact on the test object. Accordingly, no action is required. Nevertheless, countermeasures can be helpful for the functional and safety improvement of the test object. If necessary, this may give rise to risks under other circumstances.

4.3 Vulnerability States

The vulnerabilities can be in one of the following states:

- **Active:** The vulnerability has been identified and it has been possible to verify its existence through exploitation or direct evidence.
- **Potential:** The vulnerability has been identified but its exploitation has not been possible, so its existence cannot be fully verified, and it is up to the client to determine the impact.
- **Fixed:** The vulnerability has been remediated and verified through retesting.

DRAFT

5 Summary of Findings

Id	Finding Name	Risk Assessment	CVSS v3.1 Score
01	Unauthenticated access to Swagger/OpenAPI docs for B2B API	Medium	5.3
02	SQL injection in product search parameter (q)	Medium	5.3
03	Broken access control: unauthenticated access to /rest/admin application configuration	High	7.5
04	Verbose error pages on /redirect leak stack traces and internal paths	Medium	5.3
05	Unauthenticated directory listing and sensitive file download via /ftp	High	7.5
06	Information disclosure: unauthenticated access to /api/Hints reveals full hint content	Medium	5.3

6 Findings and Remediation

6.1 Finding

6.1.1 Unauthenticated access to Swagger/OpenAPI docs for B2B API

Severity	Medium
CVSS Base Score	5.3 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)
Assets	http://juiceshop:3000/api-docs/ http://juiceshop:3000/api-docs/swagger-ui-init.js
Status	open

Description

The Swagger UI and embedded OpenAPI specification for the B2B API are accessible without authentication. This discloses internal API structure (e.g., server base path /b2b/v2, available paths like POST /orders, schema examples) to anonymous users, which can materially aid endpoint discovery and targeted exploitation attempts.

Reproduction (anonymous): 1) GET http://juiceshop:3000/api-docs/ -> 200 OK (Swagger UI HTML) 2) GET http://juiceshop:3000/api-docs/swagger-ui-init.js -> 200 OK and contains an embedded OpenAPI 3.0 spec with servers.url = /b2b/v2 and paths including /orders, plus bearerAuth security scheme.

Observed behavior: docs/spec accessible to unauthenticated clients. Expected behavior: restrict API docs/spec to authenticated/admin users or disable in production.

Proof of Concept

Not provided

Remediation

Not provided

Evidence

- Response headers for GET /api-docs/ showing 200 OK without authentication.: [images/finding-fcad08db-3e83-40bc-b78e-0ab5c72603e8-3-http-20260226T211029-28522-api-docs.headers](#)

- Swagger UI HTML returned by GET /api-docs/ to an unauthenticated client.: [images/finding-fcad08db-3e83-40bc-b78e-0ab5c72603e8-4-http-20260226T211029-28522-api-docs.body](#)
- Response headers for GET /api-docs/swagger-ui-init.js confirming anonymous retrieval.: [images/finding-fcad08db-3e83-40bc-b78e-0ab5c72603e8-5-http-20260226T211005-19727-swagger-ui-init.headers](#)
- swagger-ui-init.js containing embedded OpenAPI spec (servers.url=/b2b/v2, paths include POST /orders, bearerAuth scheme) accessible without authentication.: [images/finding-fcad08db-3e83-40bc-b78e-0ab5c72603e8-6-http-20260226T211005-19727-swagger-ui-init.js](#)

6.2 Finding

6.2.1 SQL injection in product search parameter (q)

Severity	Medium
CVSS Base Score	5.3 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)
Assets	http://juiceshop:3000/rest/products/search
Status	open

Description

The anonymous product search endpoint appears vulnerable to SQL injection via the `q` parameter. A boolean-based payload alters the backend query and returns an unfiltered product list.

Reproduction (no auth): 1) Baseline search (single expected match): curl -i 'http://juiceshop:3000/rest/products/search?q=apple'

2) Inject boolean condition to bypass filtering: curl -i 'http://juiceshop:3000/rest/products/search?q=%27%29%20AND%20price<10'

Observed result: - Step 1 returns 1 product (Content-Length ~389). - Step 2 returns many products (Content-Length ~19404), indicating the WHERE clause was bypassed.

Impact: - Search filtering can be bypassed; depending on query construction this can often be extended to UNION-based extraction of additional database tables/columns (data exposure risk).

CVSS 3.1: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N (5.3)

Proof of Concept

Not provided

Remediation

Not provided

Evidence

- Injected request to /rest/products/search returns many products (q='') OR 1=1-): [images/finding-85515c3e-8261-4d83-b17d-d24ee1cc02de-1-http-products-search-sqli-20260226-0001.txt](#)
- Baseline request to /rest/products/search shows filtered result (q=apple) for comparison: [images/finding-85515c3e-8261-4d83-b17d-d24ee1cc02de-2-http-products-search-baseline-20260226-0001.txt](#)

6.3 Finding

6.3.1 Broken access control: unauthenticated access to /rest/admin application configuration

Severity	High
CVSS Base Score	7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N)
Assets	http://juiceshop:3000/rest/admin/application-configuration , http://juiceshop:3000/rest/admin/application-version
Status	open

Description

The admin REST endpoints are accessible without authentication, allowing any unauthenticated user to retrieve sensitive application configuration and version information.

Reproduction (no cookies/Authorization): 1) Request admin configuration: `curl -i http://juiceshop:3000/rest/admin/application-configuration` Observed: HTTP/1.1 200 OK with JSON body containing server/application configuration. 2) Request admin version: `curl -i http://juiceshop:3000/rest/admin/application-version` Observed: HTTP/1.1 200 OK with JSON body (e.g., {"version": "19.1.1"}).

Impact: - Exposes internal configuration data (feature flags, URLs, app settings) to unauthenticated users. - Aids targeted exploitation by disclosing exact application version and environment details.

Remediation: - Enforce authentication + role-based authorization on all /rest/admin/* routes (deny by default). - Consider reducing config surface returned and removing version disclosure for unauthenticated users.

Proof of Concept

Not provided

Remediation

Not provided

Evidence

- Unauthenticated GET /rest/admin/application-configuration returns 200 OK with full configuration JSON.: [images/finding-32146d8c-f299-42fa-afe6-9073ecbbe9ce-7-http-admin-appconfig-20260226T211026Z-22784.txt](#)
- Unauthenticated GET /rest/admin/application-version returns 200 OK disclosing application version.: [images/finding-32146d8c-f299-42fa-afe6-9073ecbbe9ce-8-http-admin-appversion-20260226T211026Z-22784.txt](#)

6.4 Finding

6.4.1 Verbose error pages on /redirect leak stack traces and internal paths

Severity	Medium
CVSS Base Score	5.3 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)
Assets	http://juiceshop:3000/redirect
Status	open

Description

The anonymous endpoint /redirect returns verbose Express error pages that include stack traces and internal filesystem paths. It also throws an unhandled exception when the required query parameter is missing, returning HTTP 500. This discloses implementation details (framework version, source file paths/line numbers) that aid targeted exploitation and debugging by an attacker.

Reproduction (no auth): 1) Request: GET http://juiceshop:3000/redirect Result: HTTP 500 with stack trace (TypeError reading 'includes') and internal paths like /juice-shop/build/lib/insecurity.js. 2) Request: GET http://juiceshop:3000/redirect?to=https://example.com Result: HTTP 406 with error page disclosing /juice-shop/build/routes/redirect.js and additional stack frames.

Expected: Generic error handling without stack traces and graceful validation errors (e.g., 400) without disclosing internal paths.

Proof of Concept

Not provided

Remediation

Not provided

Evidence

- GET /redirect (no to=) returns HTTP 500 with stack trace and internal paths: `images/finding-97d9fc8a-1b93-447f-94ed-cb49c129ba30-9-redirect-noparam-20260226T211050Z-8392.txt`
- GET /redirect?to=https://example.com returns HTTP 406 with error page disclosing source paths/line numbers: `images/finding-97d9fc8a-1b93-447f-94ed-cb49c129ba30-10-redirect-bodycheck-20260226T211020Z-3094.txt`

6.5 Finding

6.5.1 Unauthenticated directory listing and sensitive file download via /ftp

Severity	High
CVSS Base Score	7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N)
Assets	<code>http://juiceshop:3000/ftp</code> , <code>http://juiceshop:3000/ftp/incident-support.kdbx</code>
Status	open

Description

The application exposes an unauthenticated, browsable directory index at `/ftp`, allowing anonymous users to enumerate and download internal/sensitive files. The directory listing includes items such as `incident-support.kdbx` (KeePass database), dependency backups (`package-lock.json.bak`, `package.json.bak`), and order PDFs.

Reproduction (anonymous): 1) Enumerate the exposed file share: `curl -i http://juiceshop:3000/ftp` Observed: HTTP/1.1 200 OK and an HTML directory listing showing multiple files, including `incident-support.kdbx`. 2) Download a sensitive file directly: `curl -i http://juiceshop:3000/ftp/incident-support.kdbx` Observed: HTTP/1.1 200 OK with Content-Length: 3246 and the file contents are returned. 3) (Optional) Verify file type: The first bytes match the KDBX signature (`03 d9 a2 9a ...`).

Impact: - Anonymous users can obtain potentially credential-bearing secrets (KeePass DB) and other internal artifacts, enabling further compromise.

Remediation: - Disable directory indexing for static shares; remove /ftp exposure from public routing or enforce authentication/authorization. - Remove sensitive backup/secret files from web-accessible directories and rotate any credentials that may be contained within downloaded artifacts.

Proof of Concept

Not provided

Remediation

Not provided

Evidence

- GET /ftp response body showing enabled directory listing and exposed files (includes incident-support.kdbx and backup artifacts).: [images/finding-aceee4a3-9f25-4ab3-a3c5-0b06b27c869b-11-http-20260226T211014Z-3035-ftp-root.body](#)
- GET /ftp/incident-support.kdbx response headers showing anonymous 200 OK and Content-Length 3246.: [images/finding-aceee4a3-9f25-4ab3-a3c5-0b06b27c869b-12-http-20260226T211055Z-22074-ftp-incident-support-kdbx.headers](#)
- Hex dump of the first 64 bytes of incident-support.kdbx showing the KDBX file signature (03 d9 a2 9a ...).: [images/finding-aceee4a3-9f25-4ab3-a3c5-0b06b27c869b-13-xxd-20260226T211055Z-22074-incident-support-kdbx.txt](#)
- robots.txt discloses Disallow: /ftp, aiding discovery of the exposed file share.: [images/finding-aceee4a3-9f25-4ab3-a3c5-0b06b27c869b-14-http-20260226T211221Z-8294-robots.body](#)

6.6 Finding

6.6.1 Information disclosure: unauthenticated access to /api/Hints reveals full hint content

Severity	Medium
CVSS Base Score	5.3 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)
Assets	http://juiceshop:3000/api/Hints
Status	open

Description

The hints API returns full hint text to unauthenticated users, including hints marked as locked (unlocked=false).

Reproduction (no cookies/Authorization): 1) curl -i http://juiceshop:3000/api/Hints Observed: HTTP/1.1 200 OK with JSON array containing many hint entries and their full text while “unlocked”: false.

Impact: - Discloses internal hint/training content to anonymous users; in non-training contexts, comparable endpoints could leak internal guidance or sensitive operational details.

Remediation: - Require authentication and enforce per-user/role access checks before returning hint content (e.g., only return unlocked hints for the current user).

Proof of Concept

Not provided

Remediation

Not provided

Evidence

- Unauthenticated GET /api/Hints returns 200 OK and includes full hint text with “unlocked”: false.: [images/finding-156a7c9c-1184-4a2e-91e0-36cc1287a28d-15-http-api-hints-20260226T211026Z-22784.txt](#)

7 Appendix A - Lists, Scripts and Raw Data

DRAFT

8 Appendix B - List of Abbreviations

Abbreviation	Description
API	Application Programming Interface
CAPTCHA	Completely Automated Public Turing test to tell Computers and Humans Apart
CVSS	Common Vulnerability Scoring System
FTP	File Transfer Protocol
IDOR	Insecure Direct Object Reference
MD5	Message-Digest Algorithm 5
OAuth	Open Authorization
ORM	Object-Relational Mapping
OWASP	Open Web Application Security Project
PII	Personally Identifiable Information
SQL	Structured Query Language
TOTP	Time-based One-Time Password
URI	Uniform Resource Identifier
WAF	Web Application Firewall

+-----+-----+